

Αθήνα, 28-02-2024

Αριθ. Πρωτ.: 667

Απόφαση 10/2024

Η Αρχή Προστασίας Δεδομένων Προσωπικού Χαρακτήρα συνήλθε μετά από πρόσκληση του Προέδρου της σε συνεδρίαση δια ζώσης την 26.09.2023 και ώρα 10:00, προκειμένου να εξετάσει την υπόθεση που αναφέρεται στο ιστορικό της παρούσας. Παρέστησαν οι Κωνσταντίνος Μενουδάκος, Πρόεδρος της Αρχής, Χρήστος Καλλονιάτης ως εισηγητής, Σπυρίδων Βλαχόπουλος, Κωνσταντίνος Λαμπρινουδάκης, Αικατερίνη Ηλιάδου, και Γρηγόριος Τσόλιας ως τακτικά μέλη και Νικόλαος Λίβος αναπληρωματικό μέλος του Χαράλαμπου Ανθόπουλου, ο οποίος παρόλο που εκλήθη νομίμως εγγράφως δεν παρέστη, λόγω κωλύματος. Στη συνεδρίαση παρέστησαν, με εντολή του Προέδρου χωρίς δικαίωμα ψήφου, οι Παναγιώτης Τσόπελας, Λεωνίδα Ρούσος, ειδικοί επιστήμονες – ελεγκτές ως βοηθοί εισηγητή και η Ειρήνη Παπαγεωργοπούλου υπάλληλος του Τμήματος Διοικητικών Υποθέσεων της Αρχής.

Η Αρχή έλαβε υπόψη της τα παρακάτω:

Η εταιρία «ΕΛΛΗΝΙΚΑ ΤΑΧΥΔΡΟΜΕΙΑ ΑΝΩΝΥΜΗ ΕΤΑΙΡΕΙΑ», (εφεξής ΕΛΤΑ) υπέβαλε στην Αρχή, με βάση τον Κανονισμό (ΕΕ) 2016/679 (Γενικός Κανονισμός Προστασίας Δεδομένων – εφεξής ΓΚΠΔ), τις με αρ. πρωτ. Γ/ΕΙΣ/5033/23-03-2022 και με αρ. πρωτ. Γ/ΕΙΣ/9170/27-07-2022 γνωστοποιήσεις περιστατικών παραβίασης που αφορούν κρυπτογράφηση λογισμικού στο σύστημα της εταιρίας, ως αποτέλεσμα κακόβουλης επίθεσης από τρίτους, και διαρροή προσωπικών δεδομένων τα οποία, σε επόμενη φάση, δημοσιεύτηκαν στο σκοτεινό ιστό (Dark Web). Από την περαιτέρω ανάλυση της κυβερνοεπίθεσης προκύπτει ότι έλαβαν χώρα, στο πλαίσιο της παραβίασης του συστήματος του υπευθύνου επεξεργασίας, ενέργειες μη εξουσιοδοτημένης απομακρυσμένης πρόσβασης σε σταθμούς εργασίας και σε αρχεία, εύρεση εκ μέρους του επιτιθέμενου των κωδικών πρόσβασης των λογαριασμών διαχείρισης του τομέα του δικτύου, μη εξουσιοδοτημένη πρόσβαση σε αρχεία και φακέλους και εγκατάσταση κακόβουλων διεργασιών.

Η Αρχή, αφού εξέτασε την αρχική γνωστοποίηση, απέστειλε το έγγραφο με το υπ' αρ. πρωτ. Γ/ΕΞΕ/1208/19-05-2022 στα ΕΛΤΑ, ζητώντας την περιγραφή των ενεργειών που έχουν λάβει χώρα στο πλαίσιο διερεύνησης/αντιμετώπισης του εν λόγω περιστατικού και κάθε σχετική πληροφορία και αναφορά (π.χ. αναφορές προς/από άλλες αρμόδιες αρχές ή τρίτες εταιρείες), καθώς και τις ενέργειες στις οποίες τα ΕΛΤΑ έχουν προβεί σε σχέση με την ενημέρωση των επηρεαζόμενων υποκειμένων των δεδομένων και τυχόν τρίτων μερών. Τα ΕΛΤΑ απάντησαν με τα υπ' αρ. πρωτ. Γ/ΕΙΣ/7610/01-06-2022 και Γ/ΕΙΣ/7660/02-06-2022 ηλεκτρονικά μηνύματα, στα οποία περιλαμβάνονταν τεχνική έκθεση περιστατικού Κυβερνοασφάλειας, τα κεντρικά σημεία της οποίας περιγράφονται αναλυτικά στο παράρτημα Α της απόφασης και αναφέρονταν τα ακόλουθα:

1. Πραγματοποιήθηκαν ανακοινώσεις του υπευθύνου επεξεργασίας προς το κοινό για ενημέρωση σχετικά με την παραβίαση (21.03.2022 και 23.03.2022), καθώς και για τις ενέργειες μετά την παραβίαση (24.03.2022 και 07.04.2022).
2. Υπήρξε εσωτερική ανακοίνωση υπευθύνου επεξεργασίας στην οποία προσδιορίζονταν οι ενέργειες επαναφοράς του συστήματος.
3. Έγινε ενημέρωση διεθνών φορέων International Post Corporation, PostEurop, και Universal Postal Union που επηρεάζονται από το περιστατικό (22.03.2022 και 23.03.2022).
4. Έγινε ενημέρωση της Αρχής Διασφάλισης του Απορρήτου των Επικοινωνιών (24.03.2022), της Εθνικής Επιτροπής Τηλεπικοινωνιών και Ταχυδρομείων (22.03.2022) και της Εθνικής Αρχής Κυβερνοασφάλειας (30.3.2022).
5. Έγινε ενημέρωση της Εταιρίας Δικτύου Ύδρευσης και Αποχέτευσης Πρωτευούσης. Για το περιστατικό έχει υποβάλλει και η εν λόγω εταιρία αρχική αναφορά γνωστοποίησης με αρ. πρωτ. Γ/ΕΙΣ/5224/25-03-2022 και οριστική με αρ. πρωτ. Γ/ΕΙΣ/8266/24-06-2022.
6. Υποβλήθηκε συμπληρωματική γνωστοποίηση παραβίασης, με τα νέα δεδομένα που προέκυψαν κατά τη διερεύνηση του περιστατικού.

Στη συνέχεια, η Αρχή, αφού εξέτασε την ανωτέρω απάντηση, ζήτησε με το υπ' αρ. Γ/ΕΞΕ/1499/21-06-2022 έγγραφο τις πολιτικές και διαδικασίες πληροφορικής και ασφάλειας πληροφοριών του φορέα αλλά και τον τρόπο εφαρμογής των εν λόγω πολιτικών και διαδικασιών στο πλαίσιο της αντιμετώπισης του εν λόγω περιστατικού παραβίασης. Τα ΕΛΤΑ, απάντησαν με το υπ' αρ. πρωτ. Γ/ΕΙΣ/8566/06-07-2022 έγγραφο υποβάλλοντας τα ακόλουθα:

I. Την πολιτική ασφάλειας συστημάτων & δεδομένων, όπως έχει εγκριθεί κατά την 1753/01.06.2018 συνεδρίαση του διοικητικού συμβουλίου της εταιρίας, τα κεντρικά σημεία της οποίας περιγράφονται αναλυτικά στο παράρτημα Α της απόφασης.

II. Την πολιτική προστασίας της ιδιωτικότητας από τον σχεδιασμό και εξ ορισμού (privacy by default and by design), όπως έχει εγκριθεί κατά την 1868/29.12.2021 (θέμα 2ο) Συνεδρίαση του Διοικητικού Συμβουλίου στην οποία, μεταξύ άλλων, αναφέρονται τα εξής:

α. Η εταιρία εφαρμόζει από σχεδιασμό την προστασία των δεδομένων με την εφαρμογή κατάλληλων τεχνικών μέτρων ανά περίπτωση και ανά επιδιωκόμενο σκοπό σε σχέση πάντα με τον ενδεχόμενο κίνδυνο.

β. Η εταιρία διασφαλίζει εξ ορισμού ότι η πρόσβαση στα δεδομένα προσωπικού χαρακτήρα περιορίζεται μόνο σε εξουσιοδοτημένα άτομα.

γ. Η εταιρία στο πλαίσιο της προστασίας της ιδιωτικότητας ως προεπιλογή διασφαλίζει ότι τα προσωπικά δεδομένα προστατεύονται αυτόματα.

Στη συνέχεια, τα ΕΛΤΑ υπέβαλαν τη με υπ' αρ. πρωτ. Γ/ΕΙΣ/9170/27-07-2022 γνωστοποίηση περιστατικού παραβίασης, η οποία συμπληρώθηκε με την Γ/ΕΙΣ/12894/29-12-2022 γνωστοποίηση. Αναφέρεται ότι, ως επακόλουθη δράση του ανωτέρω περιστατικού, οι δράστες δημοσιοποίησαν στον σκοτεινό ιστό του Διαδικτύου (Dark Web) προσωπικά δεδομένα που υπέκλεψαν κατά την παραβίαση του συστήματος του υπευθύνου επεξεργασίας. Η Αρχή, αφού εξέτασε τη σχετική γνωστοποίηση, απέστειλε το έγγραφο με το υπ' αρ. πρωτ. Γ/ΕΞΕ/231/26-01-2023 στα ΕΛΤΑ, ζητώντας τους ονιον υπερσυνδέσμους της ομάδας Vice Society, στους οποίους βρίσκονται αναρτημένα τα προσωπικά δεδομένα που...

4

related to the aforementioned case, as well as any supplementary report available regarding this issue. The Hellenic Post (ELTA) responded with document no. Γ/ΕΙΣ/1308/21-02-2023, in which the following were submitted:

1. The hyperlink of the group on the dark web through which access to the data exists¹.
2. An investigation report from the company Netbull, which establishes that the ransomware group "Vice Society," associated with the attack on March 20, 2022, posted, on May 4, 2022, on the website it maintains on the Dark Web (Hacker Forum), data related to the attack. The report includes the contents of the directory tree and files that were posted on the website.
3. A detailed analysis of the files posted on the website, which includes subfolder name, file name, file category, category of data subjects, types of personal data, and description.

The Hellenic Post (ELTA) was summoned to a hearing on November 29, 2022, with document no. Γ/ΕΞΕ/2888/15-11-2022 from the Authority. ELTA submitted a request for postponement of the meeting on the grounds that a thorough examination of the files that had leaked to the dark web was underway, which was accepted. The Authority issued a new summons for a hearing on May 9, 2023, with document no. Γ/ΕΞΕ/1091/02-05-2023, for which ELTA submitted, with document no. Γ/ΕΙΣ/3260/04-05-2023, a request for postponement of the meeting on the grounds of a change in the legal advisor of the management. The request was accepted, and the hearing was postponed to June 6, 2023.

At the meeting on June 6, 2023, the following representatives of the data controller were present: Ioannis Giannakakis with ID no. ..., A from the General Directorate ..., B, Head of ..., Chara Zerva with ID no. ..., and Stergios Konstantinou with ID no. ..., who supported the following:

1. At the time of the cyberattack, the organization was facing serious financial difficulties. The security measures were not functioning due to this financial constraint.

2. The cyberattack began at 1:30 a.m. and was detected at 6:30 a.m. After confirming the existence of a threat, the system was taken offline, and a process of investigation, recording, categorization, classification, and updating of the involved parties began.
3. In order to better manage breach incidents, training programs for staff have been initiated.
4. Significant resources were allocated after the incident to bolster the security of the system. The actions taken post-incident concern the strengthening of the technical and organizational vulnerabilities of the system and not the alteration of the regulatory framework of the company's operations.
5. There were no alerts from the activity of the Windows Management Instrumentation Command (WMIC) tool processes due to the interruption of the network connection.

Finally, ELTA submitted, with document no. Γ/ΕΙΣ/4815/28-06-2023, a memorandum in which the following are stated:

1. Additional technical clarifications regarding the cyberattack, the main points of which are described in Annex A of the decision.
2. The vast majority of systems were recovered from backups (magnetic tapes) that had not been encrypted and from backups that were outside the infrastructure that was attacked. Some systems that were encrypted could not be recovered; however, they hosted historical data from old applications.
3. Once the cyberattack incident was detected, ELTA proceeded to immediately inform all corporate clients, who, within the framework of their collaborations with ELTA, may (depending on the type of services provided to them) act either as controllers or as processors. Specifically, regarding the collaboration of ELTA with the WATER SUPPLY AND SEWERAGE COMPANY OF GREATER ATHENS S.A. (hereinafter EYDAP), the company proceeded to a thorough update of the counterparty regarding both the incident of availability limitation and the incident of confidentiality limitation. Specifically, ELTA informed EYDAP that it acts as a processor on its behalf only concerning the services of Article 1 subparagraph (e) of the relevant contract between them: "Process of Informing EYDAP S.A.," while for other processing activities carried out by ELTA, namely the fulfillment of the universal postal service, ELTA acts as an independent data controller.
4. As evidenced by the financial statements for the years 2020, 2021, and 2022, ELTA incurred losses over the last three years. Specifically: The turnover in 2019 amounted to 355,647,000. In 2020, the turnover amounted to 318,467,000, representing a decrease of approximately 10.5%. In 2021, the turnover amounted to 299,514, representing a decrease of approximately 6%, and in the first half of 2022, the turnover amounted to 140,051,000, representing a decrease of approximately 5.4% compared to the corresponding period in 2021.

CONSIDERED ACCORDING TO THE LAW

1. According to paragraph 1, letter (f) of Article 5 of the GDPR, personal data "shall be processed in a manner that ensures appropriate security of personal data, including protection against unauthorized or unlawful processing and against accidental loss, destruction, or damage, using appropriate technical or organizational measures ('integrity and confidentiality')."

2. According to Article 32 of the GDPR:

"1. Taking into account the latest developments, the cost of implementation, and the...

7

the nature, scope, context, and purposes of the processing, as well as the risks of varying likelihood and severity for the rights and freedoms of natural persons, the data controller and the processor shall implement appropriate technical and organizational measures to ensure an adequate level of security against these risks, including, among others, as applicable:

- a) the pseudonymization and encryption of personal data,
- b) the ability to ensure the confidentiality, integrity, availability, and resilience of processing systems and services on a continuous basis,
- c) the ability to restore the availability and access to personal data in a timely manner in the event of a physical or technical incident,

d) a process for the regular testing, assessment, and evaluation of the effectiveness of the technical and organizational measures to ensure the security of processing.

2. In assessing the appropriate level of security, account shall be taken, in particular, of the risks arising from the processing, in particular from accidental or unlawful destruction, loss, alteration, unauthorized disclosure of, or access to personal data transmitted, stored, or otherwise processed.

(...)

4. The data controller and the processor shall take measures to ensure that any natural person acting under the authority of the data controller or the processor who has access to personal data processes them only on instructions from the data controller, unless he or she is required to do so by Union or Member State law.

8

3. In the case under examination, from the examination of the technical report on the cybersecurity incident, it appears that the Hellenic Post (ΕΛΤΑ) did not maintain adequate technical security measures in the system, as detailed in Appendices D and E of the decision, in violation of Article 32 of the GDPR.

4. Furthermore, from the examination of the security policy, it is found that policies were not properly implemented as detailed in Appendix F of the decision, in violation of Article 32 of the GDPR.

5. Additionally, from the notification of the incident of breach No. G/EIS/9170/27-07-2022, it appears that access was not restricted to authorized persons only, as detailed in Appendices D and E of the decision, in violation of Article 5(1)(f) of the GDPR.

6. Moreover, from the examination of the technical report on the cybersecurity incident, it appears that the activities of tracking and recognition by the perpetrator were not detected and prevented, and the security mechanisms were disabled as a result of the execution of malicious software processes, as detailed in Appendices D and E of the decision, in violation of Article 32 of the GDPR.

7. Specifically, regarding the violations mentioned in the previous paragraphs 3-6, from the entirety of the evidence in the file and the hearing process, it appears that the Hellenic Post (ΕΛΤΑ):

a. Did not ensure, through the application of the required technical and organizational measures, the protection of personal data from unauthorized or unlawful processing, resulting in a loss of confidentiality imposed by Article 5(1)(f) of the GDPR.

b. Did not implement appropriate policies for the protection of data to ensure that they could demonstrate that processing was carried out in accordance with the definitions of Article 32 of the GDPR.

c. Did not ensure the confidentiality, availability, and reliability of processing systems and services on a continuous basis and the integrity of the processes for the regular testing, assessment, and evaluation of the effectiveness of the technical and organizational measures for the security of processing, thus ensuring an adequate level of security against risks to the rights of data subjects, as per Article 32(1)(b) of the GDPR.

8. Based on the above, the Authority finds that violations of the obligations of the data controller under Articles 5(1)(f) and 32 of the GDPR have occurred. For these violations, which constitute separate infringements, there is a case for exercising the corrective powers of the Authority by imposing, in accordance with Article 58(2)(h) of the GDPR, based on the circumstances found, an effective, proportionate, and deterrent administrative fine under Article 83 of the GDPR.

9. For the determination of the fine, the following criteria are taken into account according to the EDPB Guidelines 4/2022 for the calculation of administrative fines:

I.

The turnover data, specifically:

a. Last available turnover: €140,051,000 (01/01/2022-30/06/2022).

b. Last available annual turnover for 2021: €299,514,000 (01/01/2021-31/12/2021).

c. A decrease in turnover of approximately 5.4% between the semesters 01/01/2021-30/06/2021 and 01/01/2022-30/06/2022.

II.

The fact that the severity of the identified violations is assessed in all cases as significant, taking into account:

2 https://edpb.europa.eu/our-work-tools/our-documents/guidelines/guidelines-042022-calculation-administrative-fines-under_en - version 2.0, after consultation.

3 G/EIS/4815/28-06-2023

4 G/EIS/4815/28-06-2023, <https://publicity.businessportal.gr/company/1092101000>

5 G/EIS/4815/28-06-2023

10

- a. The large number of affected individuals, namely 4,000,000 - 5,000,000, including employees of ELTA, executives, board members, lessors, customers, external collaborators, distributors, counterparties, retirees, postal agents, borrowers, guarantors, and
- b. The high extent of the damage, namely extensive data leakage concerning personal information, financial data, etc., and the loss of service availability.
- c. The occurrence of a breach of the system of the data controller, unauthorized access to resources, installation of malicious software, and publication of data on the dark web, as described in detail in Appendices Γ, Δ, E, and ΣΤ.
- d. The existence of omissions in the implementation of the security policy, inability to secure access to data from unauthorized users, insufficient technical documentation regarding the issues of collecting domain passwords and the non-utilization of warning messages about unusual activity by the protection mechanisms, as described in detail in Appendices Δ and E.
- e. The fact that particularly significant categories of personal data were affected, such as financial information of the data controller and affected companies/entities, employee data, correspondence, competitions, board meeting minutes, photographs of personnel files and customers, witness call data, witness deposition reports, universal inspection reports, database entries, lists of retirees from OGA, customer/supplier data, responsible declarations/authorizations.
- f. The fact that historical application data was not recovered. No measures were taken to limit the posting of data on the dark web.

11

III. The Authority takes into account the following mitigating factors:

- a. Following the incident, the security of the system was strengthened by taking both technical and organizational measures.
- b. There was no leakage of sensitive personal data.
- c. The data controller assigned a third company to conduct a standard incident management and response procedure and implemented all its stages.
- d. A significant portion of the data volume was restored from backups. Service availability was restored.
- e. The data controller submitted an additional notification of the breach incident, which includes detailed information about the data leakage on the dark web.
- f. At the time of the attack, the data controller was in a difficult financial situation. The company was showing losses in its turnover until 30/6/2022.

10. Following the consideration of the above aggravating and mitigating criteria (consideration 9 points ii) and iii) above), as well as the turnover data of the data controller (consideration 9 point i) above), the Authority deems that a fine should be imposed on the company named "ΕΛΛΗΝΙΚΑ ΤΑΧΥΔΡΟΜΕΙΑ ΑΝΩΝΥΜΗ ΕΤΑΙΡΕΙΑ" close to the lower end of the static range defined by the guidelines 4/2022 of the EDPB for violations of high severity and equal to 1% of the last available annual turnover of the data controller.

FOR THESE REASONS

The Authority

Exercising its corrective powers based on Article 58 paragraph 2 point (h) of the GDPR, imposes a fine of two million nine hundred ninety-five thousand one hundred forty euros (€2,995,140) on the company

named "ΕΛΛΗΝΙΚΑ ΤΑΧΥΔΡΟΜΕΙΑ ΑΝΩΝΥΜΗ ΕΤΑΙΡΕΙΑ," for the reasons extensively outlined in the reasoning.

The President

The Secretary

Konstantinos Menoudakos

Irini Papageorgopoulou